



Monthly Security & Compliance Report

Platform security posture for the 31-day window ending Jul 31, 2026. Covers Curation supply chain gate activity, Xray vulnerability analysis, and prioritized remediation actions.

Period • Jul 1, 2026 – Jul 31, 2026 Instance • solenglATEST.jfrog.io Generated • 2026-07-31

Schema • 2.0-beta

SECURITY POSTURE AT A GLANCE

500

Critical violations
497 more vs prior

727

Packages blocked
of 42,856 screened

28,245

Total violations
0 high, 0 medium

77%

Xray indexed
846 of 1,094 repos

18

Active developers

82%

Curation coverage

15

Active watches

120

Enforcing policies

Critical violations increased from 3 to 500 (+497) since the prior period.

PERIOD COMPARISON

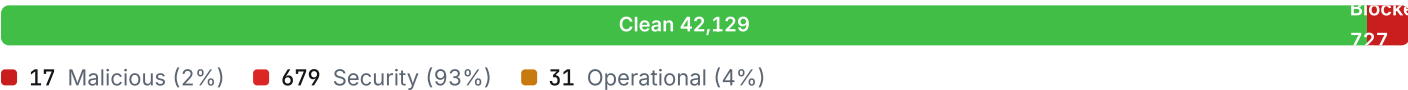
Change from prior report

METRIC	CURRENT	PREVIOUS	CHANGE
Critical violations	500	3	+497
Total violations	28,245	94	+28,151
Packages blocked	727	0	+727
Packages screened	42,856	0	+42,856

01 · CURATION

Supply chain gate

Package screening



42,129

Clean packages allowed
after policy evaluation

0

Requests without
inspection

18

Pending waiver requests

20.8%

Upgrade-after-block rate

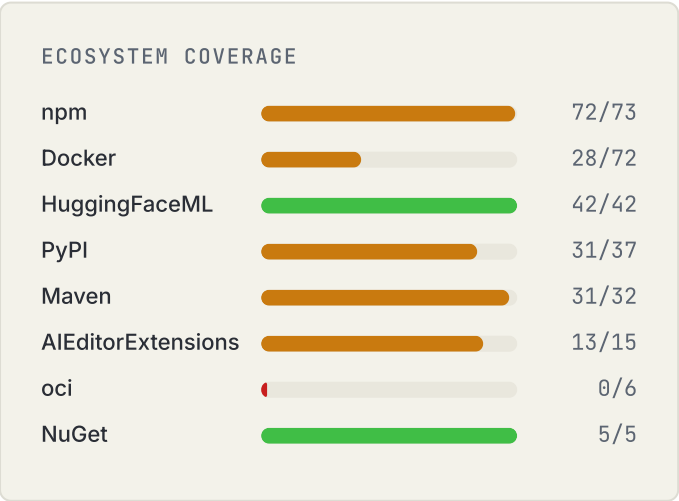
18

active developers using the Curation gate

42,856 package requests screened this period

DEVELOPER	REQUESTS	APPROVED	BLOCKED	BLOCK RATE
shanil	17,801	17,713	88	—
rodolphef@jfrog.com	13,624	13,624	0	—
ananthak	3,099	3,099	0	—
umac@jfrog.com	1,549	1,514	35	2%
tomokim@jfrog.com	1,512	1,476	36	2%
jfxsbm@01j15c8zmbb08rywgndaaqjwe8	1,219	1,214	5	—
davidli	999	976	23	2%
smadhan@jfrog.com	964	460	504	52%
maharship	912	907	5	1%
joerns	499	484	15	3%
token:tomokim-solenglatest-github-oidc/cocoa-maemae	182	179	3	2%
anubhavk	116	108	8	7%
token:tomokim-solenglatest-github-oidc/dependabot[bot]	103	103	0	—
marcelol@jfrog.com	95	95	0	—
petrof	86	86	0	—

and 3 additional developers



POLICY SUMMARY

154 Curation policies registered

120 enforcing (Block action)

27 Dry Run (observe only)

242 of 296 supported remotes connected

Top blocked packages

PACKAGE	ECOSYSTEM	REASON	BLOCKS
jfrog-curation-malicious-dummy	npm	MALICIOUS	7
cors.js	npm	MALICIOUS	5
abuden2	npm	MALICIOUS	3
strapi-plugin-config	npm	MALICIOUS	2
lodash	npm	Policy violation	44
ejs	npm	Policy violation	41
axios	npm	Policy violation	24
debug	npm	Policy violation	11
minimist	npm	Policy violation	10
source-map	npm	Policy violation	10
wordwrap	npm	Policy violation	10
handlebars	npm	Policy violation	9
curl	npm	Policy violation	8
ms	npm	Policy violation	8
click	PyPI	Policy violation	7

Protection by policy

POLICY	SCOPE	BLOCKED	CLEAN	BLOCK %	CLEAN %
sai-curation-block-policy	Seen in audit only	461	0	100%	0%
shani-high-cvss-9	Selected repositories	88	6	93.6%	6.4%
tomokim-npm-block-policy-cvss-9-or-above	Selected repositories	38	0	100%	0%
sai-block-npm-cvss	Selected repositories	30	0	100%	0%
jml-sai-npm	Seen in audit only	28	0	100%	0%
14day-umac-policy	Selected repositories	27	0	100%	0%
davidli-npm-strict	Selected repositories	10	0	100%	0%
jml-rsa-demo-pypi	Selected repositories	10	0	100%	0%

POLICY	SCOPE	BLOCKED	CLEAN	BLOCK %	CLEAN %
joern-curl-version	Selected repositories	8	0	100%	0%
joern-block-malicious	Selected repositories	7	0	100%	0%
sai-block-cvss	Seen in audit only	6	0	100%	0%
Cvs7-above	Selected repositories	5	0	100%	0%
anubhav-high-critical-cve	Selected repositories	5	0	100%	0%
shani-malicious-packages	Selected repositories	5	0	100%	0%
aged packages	All remote repositories	3	0	100%	0%
frogs-npm-malicious-block	Selected repositories	3	0	100%	0%
anubhav-malicious-policy	Selected repositories	2	0	100%	0%
anubhav-immature-policy	Selected repositories	1	0	100%	0%
sai-block-npm-axios	Seen in audit only	1	0	100%	0%
tomokim-block-policy-eol	Seen in audit only	1	0	100%	0%

RECOMMENDED BASELINE

Block malicious org-wide: Missing

No matching policy discovered

CACHED-PACKAGE ENFORCEMENT

29 / 120 blocking policies cover cached packages

Global setting: not exposed

Policies still in Dry Run

POLICY	SCOPE	DAYS IN DRY RUN
block_aged_package_with_newer_version	All remote repositories	73
block_aged_package_without_newer_version	All remote repositories	73
block_cvss_4to7_with_fix_version	All remote repositories	4
block_cvss_4to7_with_or_without_fix_version	All remote repositories	73
block_cvss_7to9_with_fix_version	All remote repositories	73
block_cvss_7to9_with_or_without_fix_version	All remote repositories	73
block_cvss_9to10_with_fix_version	All remote repositories	73

POLICY	SCOPE	DAYS IN DRY RUN
block_cvss_9to10_with_or_without_fix_version	All remote repositories	73
block_image_not_offical_docker_hub	All remote repositories	73
block_license_AGPL	All remote repositories	73
block_license_GPL	All remote repositories	73
block_license_LGPL	All remote repositories	73
block_no_license	All remote repositories	73
Block Released Less Than 30 Days	Selected repositories	93
guy-dry-run	Selected repositories	327
guy-warn-viral-licenses	Selected repositories	39
jml-agentic-development-lab-npm	Selected repositories	37
jml-yoitsmikeho-npm	Selected repositories	92
kushatest	pkg_types	93
mikios-test-aiextension	pkg_types	52
rodolphef-exploitability	Selected repositories	161
rodolphe-security	Selected repositories	161
rsa-block-packages-with-critical-CVEs	Selected repositories	135
rsa-immaturity-policy	Selected repositories	135
sai-block-npm-axios	Selected repositories	14
sai-curation-block-policy	Selected repositories	15
tomokim-block-policy-eol	Selected repositories	16

Remote repositories outside the Curation gate

REPOSITORY	PACKAGE TYPE	COVERAGE
hza-vscode-remote	AIEditorExtensions	Not enabled
test-vscode-remote	AIEditorExtensions	Not enabled
ai-catalog-demo-ai-catalog-demo-docker-remote	Docker	Not enabled
ai-catalog-demo-nim-dr	Docker	Not enabled

REPOSITORY	PACKAGE TYPE	COVERAGE
alex-alex-docker-remote	Docker	Not enabled
avi-avi-docker-remote	Docker	Not enabled
avi-ghrc-docker-remote	Docker	Not enabled
btwallet-docker-remote	Docker	Not enabled
carm-carm-docker-remote	Docker	Not enabled
dckr-ai-ml-remote	Docker	Not enabled
dckr-base-images-remote	Docker	Not enabled
dckr-cicd-remote	Docker	Not enabled
dckr-databases-remote	Docker	Not enabled
dckr-k8s-tooling	Docker	Not enabled
dckr-observability-remote	Docker	Not enabled
dckr-security-remote	Docker	Not enabled
dckr-utilities-remote	Docker	Not enabled
docker-hamzaztest	Docker	Not enabled
docker-remote-hza	Docker	Not enabled
docker-remote-k8s-io	Docker	Not enabled
dro-release-proxy	Docker	Not enabled
dylanmo-dylanmo-docker-remote	Docker	Not enabled
gn-gn-docker-remote	Docker	Not enabled
guy-guy-docker-remote	Docker	Not enabled
guyes-guyes-docker-remote	Docker	Not enabled

Vulnerability posture

REMIEDIATION READINESS

0

SLA breaches
Critical violations over 30 days

11

Fixable issues
Patch or upgrade available

1

Watch blind spots
Repos with violations, no watch

BY SEVERITY

0

500 Critical

0 High

0 Medium

0 Low

BY POLICY TYPE

00

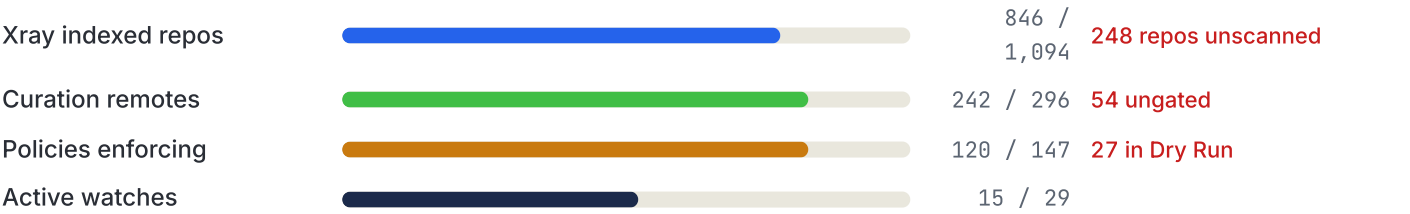
500 Security

0 Operational

0 License

Platform configuration

15 of 29 Xray watches active · 50 Xray policies (43 security, 3 license, 4 operational risk)



Top exposure

ISSUE	COMPONENT	SEVERITY	ARTIFACT HITS
XRAY-983975	3.9.17	CRITICAL	24
XRAY-104518	0.1.3	CRITICAL	24
XRAY-936478	3.9.17	CRITICAL	24
XRAY-979650	3.9.17	CRITICAL	24
XRAY-947352	2.0.6	CRITICAL	24

All findings (top 20)

ISSUE	COMPONENT	SEVERITY	ARTIFACTS
XRAY-988717	0.31.0	CRITICAL	—
XRAY-657442	0.29.0	CRITICAL	—
XRAY-988717	0.31.0	CRITICAL	—
XRAY-988717	0.31.0	CRITICAL	—
XRAY-657442	0.29.0	CRITICAL	—
XRAY-988717	0.31.0	CRITICAL	—
XRAY-983975	3.9.17	CRITICAL	—
XRAY-104518	0.1.3	CRITICAL	—
XRAY-72506	0.4.0	CRITICAL	—
XRAY-936478	3.9.17	CRITICAL	—
XRAY-979650	3.9.17	CRITICAL	—
XRAY-947352	2.0.6	CRITICAL	—
XRAY-979649	3.9.17	CRITICAL	—
XRAY-534513	3.3.0	CRITICAL	—
XRAY-520258	3.9.17	CRITICAL	—
XRAY-979650	3.9.17	CRITICAL	—
XRAY-978076	3.9.17	CRITICAL	—
XRAY-992823	3.9.17	CRITICAL	—
XRAY-72506	0.1.0	CRITICAL	—
XRAY-992798	3.9.17	CRITICAL	—

Critical issue work queue

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-104518	0.1.3	available	unknown	—	24	24
XRAY-936478	3.9.17	available	unknown	—	24	24
XRAY-947352	2.0.6	unknown	unknown	—	24	24
XRAY-979649	3.9.17	available	unknown	—	24	24

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-979650	3.9.17	available	unknown	—	24	24
XRAY-983975	3.9.17	available	unknown	—	24	24
XRAY-72506	0.4.0	unknown	unknown	—	23	24
XRAY-1019545	4.2.1	unknown	unknown	—	12	24
XRAY-520258	3.9.17	unknown	unknown	—	12	24
XRAY-522747	2.5.0	unknown	unknown	—	12	24
XRAY-526362	3.9.17	unknown	unknown	—	12	24
XRAY-534513	3.3.0	unknown	unknown	—	12	24
XRAY-600113	1.0.11	unknown	unknown	—	12	24
XRAY-600115	1.0.11	unknown	unknown	—	12	24
XRAY-85679	2.4.2	unknown	unknown	—	12	24
XRAY-91651	0.6.11	unknown	unknown	—	12	24
XRAY-957948	4.7.7	available	unknown	—	12	24
XRAY-959813	4.17.21	available	unknown	—	12	24
XRAY-975816	3.9.17	unknown	unknown	—	12	24
XRAY-976249	3.9.17	unknown	unknown	—	12	24
XRAY-976250	3.9.17	unknown	unknown	—	12	24
XRAY-976251	3.9.17	unknown	unknown	—	12	24
XRAY-978074	3.9.17	available	unknown	—	12	24
XRAY-978075	3.9.17	available	unknown	—	12	24
XRAY-992800	3.9.17	unknown	unknown	—	12	24
XRAY-992821	3.9.17	unknown	unknown	—	12	24
XRAY-523322	3.9.17	unknown	unknown	—	11	24
XRAY-711280	2.3.3	unknown	unknown	—	11	24
XRAY-968520	2.31-13+deb11u10	unknown	unknown	—	11	24
XRAY-976252	3.9.17	unknown	unknown	—	11	24
XRAY-978076	3.9.17	available	unknown	—	11	24

ISSUE	COMPONENT	FIX	EXPLOIT	ENVIRONMENT	HITS	DAYS
XRAY-978088	3.9.17	available	unknown	—	11	24
XRAY-992798	3.9.17	unknown	unknown	—	11	24
XRAY-992822	3.9.17	unknown	unknown	—	11	24
XRAY-992823	3.9.17	unknown	unknown	—	11	24
XRAY-988717	0.31.0	unknown	unknown	—	4	24
XRAY-657442	0.29.0	unknown	unknown	—	2	24

Repositories with the most exposure

REPOSITORY	SERVICE	CRITICALITY	ENVIRONMENT	CRITICAL	TOTAL
guy-docker-dev-local	—	unknown	—	500	500

Watch-to-repository coverage

REPOSITORY	WATCHES	CRITICAL	RISK
guy-docker-dev-local	0	500	critical

LICENSE COMPLIANCE

0 license violations

OPERATIONAL RISK

0 operational violations

Prioritized remediation

01 Patch 11 critical issues with available fixes

Fixed versions already exist. These are the fastest exposure reducers.

P1

Effort: Medium

190 artifact hits

02 Create Xray watches for 1 repositories with violations

guy-docker-dev-local has 500 violations with no watch assigned.

P1

Effort: Low

500 critical in unwatched repos

03 Index 248 repositories in Xray

23% of repos have no Xray indexing. Violations there are invisible.

P1

Effort: Medium

846/1,094 indexed

04 Remediate 500 critical violations

Assign remediation owners to the highest-hit XRAY issue IDs.

P1

Effort: High

500 critical, 0 high

05 Patch 11 critical issues with known fixes

Impact: these fixes remove 190 artifact hits without waiting for compensating controls. Next step: prioritize components in Highest-Impact Fixes.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 94

06 Assign watches to 1 repositories with violations

Impact: the top blind spot (guy-docker-dev-local) has 500 violations and no watch mapping. Next step: attach the repository to an active Xray watch.

P1

Effort: Low

Owner: Security Operations

Due: 2026-08-07

Score: 92

07 Remediate vm2:3.9.17 (XRAY-936478, XRAY-979649, XRAY-979650 + 18 more — 293 hits)

Impact: vm2 is an open source vm/sandbox for Node.js. In vm2 prior to version 3.10.2, `Promise.prototype.then` `Promise.prototype`. Next step: review affected artifacts in Xray console for XRAY-936478.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 98

08 Remediate express-jwt:0.1.3 (XRAY-104518 — 24 hits)

Impact: In express-jwt (NPM package) up and including version 5.3.3, the algorithms entry to be specified in the configuration i. Next step: review affected artifacts in Xray console for XRAY-104518.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 82

09 Remediate dottie:2.0.6 (XRAY-947352 — 24 hits)

Impact: Dottie provides nested object access and manipulation in JavaScript. Versions 2.0.4 through 2.0.6 contain an incomplete . Next step: review affected artifacts in Xray console for XRAY-947352.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 82

10 Remediate libxmljs:1.0.11 (XRAY-600113, XRAY-600115 — 24 hits)

Impact: libxmljs is vulnerable to a type confusion vulnerability when parsing a specially crafted XML while invoking the namespa. Next step: review affected artifacts in Xray console for XRAY-600113.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 82

11 Remediate jsonwebtoken:0.4.0 (XRAY-72506 — 23 hits)

Impact: In jsonwebtoken node module before 4.2.2 it is possible for an attacker to bypass verification when a token digitally si. Next step: review affected artifacts in Xray console for XRAY-72506.

P1

Effort: Medium

Owner: Security Operations

Due: 2026-08-07

Score: 81

12 Promote 27 Curation policies from Dry Run to Block

Dry Run policies detect but never block downloads. Promoting closes the gap immediately.

P2

Effort: Low

120 blocking, 27 Dry Run

13 Connect 54 supported remotes to Curation

These remote repositories serve packages without curation screening.

P2

Effort: Low

242/296 connected

14 Connect 53 supported remotes to the Curation gate

Impact: supported remotes can bypass policy checks today, led by Docker. Next step: connect these repositories in Curation repository settings.

P2

Effort: Low

Owner: Platform Security

Due: 2026-08-30

Score: 84

15 Extend Xray coverage to 248 unindexed repositories (23% blind spot)

Impact: 23% coverage gap means violations in 248 repos are invisible to any watch or policy. Next step: enable indexing on all remote repos via Xray → Repositories → Indexed Resources, prioritizing Docker, npm, and Maven.

P2

Effort: Medium

Owner: Platform Security

Due: 2026-08-30

Score: 80

16

Promote 27 dry-run curation policies to block mode

Impact: 27 policies are running in dry-run (audit-only). Promoting them to block mode would increase enforced gate coverage. Next step: review audit-log false-positive rate, then enable block mode in Curation policy settings.

P2

Effort: Low

Owner: Platform Security

Due: 2026-08-30

Score: 72

17

Review 14 inactive Xray watches

14 of 29 watches are not active.

P3

Effort: Low

15/29 active

04 · TREND

Threat velocity

PERIOD	CRITICAL	VIOLATIONS	GATE BLOCKS
2026-06-30	3	94	0
2026-07-31	500	28,245	727

Across 2 reports, critical findings rose from 3 to 500; total violations rose from 94 to 28245, while gate blocks moved from 0 to 727. Prioritize the oldest fixable critical issues and owners this week.